

1. Executive Summary

This report provides a technical forensic analysis of four distinct phishing campaigns targeting various platforms, including financial services, cloud providers, and institutional security alerts. The investigation confirms that attackers are successfully bypassing traditional Email Security Gateways by leveraging compromised legitimate infrastructure, employing sophisticated Unicode obfuscation, and utilizing "Reverse-BEC" (Business Email Compromise) tactics. The findings demonstrate that standard reputation-based filtering is insufficient, and that robust employee awareness training is critical to mitigating these highly deceptive social engineering attacks.

2. Findings Table: Sample 01 (Bank/Financial Impersonation)

Field	Analysis Details
Target	Trust Wallet
From Address	comunicacioncorporativa@ucv.edu.pe
SPF / DKIM / DMARC	SPF: PASS, DKIM: PASS, DMARC: PERMERROR
Origin IP	185.98.145.214 (Reputation: Clean)
Domain Investigation	Legitimate university domain (ucv.edu.pe) - Infrastructure Hijack
Classification	PHISHING (CRITICAL RISK)

Justification & Attack Mechanics:

This campaign utilizes a high-level "Infrastructure Hijacking" technique. Because the email originates from a legitimate, high-reputation university domain (ucv.edu.pe), it bypassed all standard SPF and DKIM security checks. The attacker has compromised the university's email marketing platform to ensure 100% deliverability. The email uses urgent, fear-based language regarding wallet suspension to manipulate the victim into revealing sensitive recovery phrases.

3. Findings Table: Sample 02 (Cloud Service Impersonation)

Field	Analysis Details
Target	Apple iCloud
From Address	otto-newsletter@newsletter.otto.de
SPF / DKIM / DMARC	SPF: PASS, DKIM: NONE, DMARC: FAIL
Origin IP	80.96.157.91 (Reputation: Blacklisted - Spamhaus ZEN)
Domain Investigation	Recently Registered — New Domain
Classification	PHISHING (HIGH RISK)

Justification & Attack Mechanics:

This campaign utilizes **Unicode obfuscation**, specifically replacing standard characters with mathematical symbols (e.g., iCloud) to bypass text-based security filters. The email claims to be a critical storage alert from iCloud, but originates from a compromised retail newsletter domain (otto.de). The inclusion of the IP on the **Spamhaus ZEN blacklist** confirms this infrastructure is actively used for malicious activity.

4. Findings Table: Sample 03 (Security Alert Impersonation)

Field	Analysis Details
Target	Microsoft / BEC
From Address	no-reply@access-accsecurity.com

SPF / DKIM / DMARC	SPF: NONE, DKIM: NONE, DMARC: PERMERROR
Origin IP	89.144.44.2 (Reputation: Clean)
Domain Investigation	Recently Registered — Typosquatting
Classification	PHISHING (CRITICAL RISK)

Justification & Attack Mechanics:

This sample utilizes a "**Reverse-BEC**" tactic. By providing a "Report" button linked to a [mailto: address \(sotrecognizd@gmail.com\)](mailto:sotrecognizd@gmail.com), the attacker attempts to establish direct, unmonitored communication with the victim to facilitate social engineering. The domain access-accsecurity.com is a clear typosquatting attempt designed to mimic legitimate Microsoft security infrastructure.

5. Findings Table: Sample 04 (Account Verification)

Field	Analysis Details
Target	Generic Account Verification
From Address	llCIEHT@bruidswinkel.site
SPF / DKIM / DMARC	SPF: PASS, DKIM: NONE, DMARC: BESTGUESSPASS
Origin IP	77.91.100.82 (Reputation: Clean)
Domain Investigation	Recently Registered — Throwaway Domain

Classification	SUSPICIOUS (MEDIUM RISK)
-----------------------	---------------------------------

Justification & Attack Mechanics:

This sample uses a "low-noise" registration tactic. The attacker uses a recently registered, low-reputation [.site](#) domain to send out mass verification requests. While it lacks the high-intensity psychological pressure of the other samples, its primary purpose is reconnaissance—to verify which email addresses are active and monitored by users, allowing the attacker to build a "validated" target list for future, more sophisticated spear-phishing campaigns.

6. Prevention Guidelines for Employees

To protect yourself and the organization, please follow these guidelines:

1. **Inspect the Sender:** Always check the actual email address, not just the display name. Look for typos (e.g., [paypal.com](#) vs [paypal.com](#)).
2. **Hover Before Clicking:** Hover your mouse over any link to preview the actual destination URL before clicking.
3. **Verify Urgency:** Be skeptical of emails that demand "immediate action" or create false time pressure, as these are designed to bypass critical thinking.
4. **Avoid "Mailto" Links:** If clicking a button opens an email draft, close it immediately; do not engage with the attacker.
5. **Use Official Channels:** Always access your accounts by typing the URL directly into your browser rather than clicking links provided in emails.
6. **Report Suspicious Activity:** If an email feels "off," report it to the IT security team immediately.

Quick Reference: Do's and Don'ts

Do	Don't
Do verify the sender's full email address	Don't trust the email display name
Do hover over links before clicking	Don't click links in urgent/fear-based emails
Do report suspicious emails to IT	Don't forward suspicious emails to colleagues
Do log into sites via official bookmarks	Don't enter credentials from email links

Final Task Checklist

Your report is now structurally complete. Ensure you follow these final steps to submit:

- **Export:** Save your document as a professional PDF.
- **Organize:** Ensure your [samples/](#) and [screenshots/](#) folders are organized within your [FUTURE_CS_02](#) repository.
- **Finalize README:** Ensure your [README.md](#) is updated with your specific findings and the references listed in your guide.
- **Submission:** Submit via the official portal using your CIN ID.